AI Governance For Startups Cheat Sheet

6 printable pages of the actual AI governance program you need to ship in 30 days. Pin the 1-pager to your wall. Use the tracker every week. Stop "we'll add governance later" and start shipping.

Page 1 -- The Four Artifacts (wall poster)

The only four documents an AI startup needs to pass enterprise procurement and survive an EU AI Act audit.

- 1. **Model card.** One page per model. Intended use, out-of-scope use, training data, eval results, known limitations. Use Google's template.
- 2. **Risk tier.** Every model gets a tier 1-4. Tier 3 (automated decisions affecting people) needs a conformity assessment. Tier 4 is prohibited. Most startups should have zero of either.
- 3. **Data lineage.** For each model: where did training data come from, when, what consent, how to delete. The most-failed audit item.
- 4. **Change log.** Git-style log of every model release: what changed, who approved, what tests, what rollback plan.

If you have these four documents and they're current, you can pass an enterprise security review. Everything else is decoration.

Page 2 -- The 30-Day Calendar

Week	Action	Owner	Done?
1	Inventory all models in production. List intended use.	Founder + Eng	[ ]
2	Risk tier every model (1-4). Block 2 days for tier 3 conformity assessment if any.	Founder	[ ]
3	Write 4 model cards for tier 2+. Data lineage. Change log.	Founder + Eng	[ ]
4	Fill largest enterprise security questionnaire using only these 4 artifacts.	Founder	[ ]

The hardest day is day 14. That's when you assign risk tiers and discover 2-3x more models than you thought. That's normal. The point is to know.

Page 3 -- Weekly AI Governance Checklist

Print this. Every Friday, walk through it. 15 minutes. That's the whole program.

```
```

Friday AI Governance Check (15 min)

[ ] Any new models in production this week? Add to inventory.

[ ] Any model retrained? Update data lineage + change log.

[ ] Any model version bump? New model card entry + rollback plan.

[ ] Any new customer use case that's high-stakes? Re-tier the model.

[ ] Any new vendor providing AI components? Add to vendor list.

[ ] Quarterly bias audit due? Run Fairlearn / Aequitas this week.

[ ] Quarterly access review? Remove dormant model access.

[ ] Any incidents or near-misses? Update incident log.

```

**Done. That's the whole Friday ritual.** Auditors love seeing this checklist completed weekly.

---

## Page 4 -- The Risk Tiering Cheat Sheet

```

EU AI Act + NIST AI RMF -- Risk Tiers

TIER 1 (minimal risk) Examples: spam filter, internal tool,
                       game NPC, autocomplete.
                       Obligations: none.

TIER 2 (limited risk) Examples: chatbot, content
                       recommendation, image generation,
                       code autocomplete.
                       Obligations: disclose AI to users,
                       label AI-generated outputs.

TIER 3 (high risk)   Examples: credit scoring, hiring
                       decisions, medical diagnosis,
                       education scoring, biometric ID,
                       critical infrastructure.
                       Obligations: full conformity
                       assessment, data governance, human

oversight, accuracy testing,
robustness testing, change log.

TIER 4 (prohibited) Examples: social scoring by governments, subliminal manipulation, real-time biometric ID in public spaces (with narrow exceptions).
Obligations: do not build. Period.

```

**The honest answer for most AI startups:** 80% of your models are tier 1 or 2, 0-2 are tier 3, 0 are tier 4. If you have tier 3, the conformity assessment is a 30-page document -- block 4 weeks. If you have tier 4, stop and talk to a lawyer.

---

## Page 5 -- The Model Card Skeleton

```
MODEL CARD -- [Model Name] v[Version]

Model type: [e.g., fine-tuned GPT-4o, custom transformer]
Intended use: [What it's designed to do. Who uses it.]
Out-of-scope: [What it should NOT be used for.]
Training data: [Source, size, date range, consent basis]
Eval results: [Date + accuracy / bias / safety metrics]
Known limits: [Where it fails. Edge cases. Adversarial inputs.]
Contact: [Email or Slack channel for issues]
Last updated: [Date]
```

**One model card per model. One page each. Update on every release.** The Google model card template at `modelcards.withgoogle.com` is the canonical reference.

---

## Page 6 -- The Bias Test Recipe (run quarterly)

```

QUARTERLY BIAS TEST

Pick one tier 2+ model.

Pick one protected attribute: race, gender, age, disability.

Pick one fairness metric: demographic parity, equalized odds.

Run the test:

- Fairlearn (Python): pip install fairlearn
- Aequitas (web UI): github.com/dssg/aequitas

Document the result:

- "Model X has <metric> of Y across <groups>. Acceptable per policy Z."
- Or: "Model X shows bias. Mitigation: retrain on balanced data by Q2."

File the report in: /governance/bias-audits/YYYY-QN.md

```

**This is 3-5 days of work, not 3-5 weeks.** Auditors care more about "you tested and found X" than "we have no bias." The former is governance. The latter is a liability.

**If a test shows bias, document the mitigation plan and the timeline.** A bias finding with a plan is governance. A bias finding without a plan is a lawsuit.
```